

 **API key connected**
● Ready to analyze · Key stored locally in your browser

Disconnect



Cloud Network Security Advisor

AI-powered security posture analysis · gap detection · hardening recommendations · 90-day action plan

 NETWORK TOPOLOGY & ENVIRONMENT

Enterprise private cloud running VMware Cloud Foundation (VCF) across 3 data centers. North-south traffic managed by a traditional perimeter firewall with basic ACLs. East-west traffic between workloads is largely flat with no microsegmentation applied. Remote workforce access via legacy VPN with no MFA enforced. No consistent network monitoring or visibility into lateral movement between workloads. A recent merger added 2,000 new endpoints with unknown security posture integrated into the same flat

 CURRENT SECURITY TOOLS

- ☒ VMware NSX
- ☐ NSX ALB / Avi
- ☐ SD-WAN
- ☐ IDS / IPS
- ☒ Zero Trust
- ☐ PAM
- ☐ vDefend ATP
- ☐ SASE
- ☒ Traditional Firewall
- ☒ SIEM
- ☐ EDR / XDR
- ☐ None currently

 COMPLIANCE REQUIREMENTS

- ☒ NIST CSF
- ☒ SOC 2
- ☐ HIPAA
- ☐ GDPR
- ☐ ISO 27001
- ☐ PCI-DSS
- ☐ FedRAMP
- ☐ None specified

 ENVIRONMENT CONTEXT

Environment type

Multi-cloud

▼

Security maturity level

Managed — metrics-driven

▼

 Analyze security posture

 Load sample scenario

 Clear

Analysis complete

 Export to Excel

Critical risk · multi-cloud



The organization faces severe security posture deficiencies across network segmentation, access control, and multi-cloud visibility, creating elevated risk for lateral movement, data exfiltration, and compliance violations. The flat network topology combined with legacy VPN, newly integrated merger assets with unknown security posture, and inconsistent cross-cloud policy enforcement creates a critical attack surface. Immediate intervention is required to implement Zero Trust architecture, NSX microsegmentation, and unified security policy enforcement across all environments.



Security gaps

13 identified · sorted by severity

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
Critical	No East-West Microsegmentation	Flat network topology allows unrestricted lateral movement between workloads within VCF environments. Absence of NSX distributed firewall means any compromised workload can pivot laterally to access sensitive systems and data without detection or prevention.	Implement NSX distributed firewall with application-level microsegmentation policies. Deploy NSX Service Mesh or equivalent to enforce zero-trust communication between workloads based on identity and application context, not just IP/port combinations.
Critical	Weak Remote Access Controls	Legacy VPN without MFA creates high-risk entry point for credential-based attacks, especially vulnerable to compromised user accounts during merger integration when endpoint management is inconsistent. No session inspection or adaptive authentication posture validation.	Replace legacy VPN with SASE solution (VMware SD-WAN + vDefend ATP integrated with Okta/Entra ID MFA). Enforce certificate-based authentication, device posture checking, and continuous compliance validation before granting access. Implement conditional access policies based on user, device, location, and threat intelligence.
Critical	Unknown Security Posture - 2,000 Merger Endpoints	Post-merger integration of 2,000 endpoints with unvalidated security configurations into flat network creates uncontrolled attack surface. No inventory, vulnerability assessment, or compliance baseline established for merged assets. These endpoints can	Immediately inventory and assess all 2,000 merger endpoints using NSX Network Detection and Response (NDR) and integrated vulnerability scanning. Implement quarantine VLAN for non-compliant devices. Enforce mandatory baseline hardening (patch level, antivirus, encryption) before network trust elevation. Use NSX micro-

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
		propagate malware, establish beachheads for lateral movement, or exfiltrate data.	segmentation to isolate merger workloads until compliance verified.
Critical	Inconsistent Multi-Cloud Policy Enforcement	AWS and Azure workloads connected via site-to-site VPN lack unified security policy framework. No consistent threat detection, access controls, or data protection policies across environments. Cloud-native security groups and NACLs configured independently without correlation to on-premises Zero Trust architecture, creating policy gaps and detection blind spots.	Deploy VMware SD-WAN with centralized policy management across all clouds. Implement consistent network segmentation policies using infrastructure-as-code (Terraform/Ansible). Establish unified SIEM ingestion from AWS (CloudTrail, VPC Flow Logs), Azure (Network Watcher, Activity Logs), and NSX to correlate threats across boundaries. Use vDefend ATP for cloud-native workload protection.
Critical	Absence of Network Visibility and Lateral Movement Detection	No consistent monitoring of east-west traffic means lateral movement, command-and-control communications, and data exfiltration occurring within network are undetected. SIEM lacks NSX integration to capture application-level flow context. Threat actors can move between systems without triggering alerts or forensic evidence capture.	Integrate NSX with SIEM (Splunk/ELK) to ingest flow telemetry, application metadata, and security events at scale. Deploy NSX NDR or Cisco Tetration for behavioral analytics and anomaly detection on lateral movement patterns. Implement real-time alerting for suspicious east-west connections. Establish baseline communication patterns using machine learning to detect deviations.
High	North-South Traffic Lacks Intelligent Inspection	Traditional perimeter firewall with basic ACLs provides no application-layer visibility, threat inspection, or policy-based enforcement based on user identity and workload context. Encrypted traffic bypasses inspection. No integration with threat intelligence or Zero Trust architecture. Potential for ingress of malware and exfiltration of sensitive data undetected.	Upgrade perimeter security with NSX Advanced Load Balancer (ALB) for SSL/TLS inspection and application-aware routing. Integrate threat prevention (IPS/ATP) with vDefend ATP for real-time threat blocking. Implement identity-aware access policies at the edge using vDefend SASE capabilities. Enforce DLP policies on outbound data channels.
High	No Workload-Level Identity and Access	Absence of workload identity framework means no	Implement VMware NSX Service Mesh or HashiCorp Consul for

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
	Control	cryptographic authentication between services. Static network credentials or implicit trust based on network segment. Service-to-service communications not authenticated or authorized, enabling service account compromise to lead to lateral movement.	mTLS-based service-to-service authentication. Deploy Kubernetes pod security policies and network policies for containerized workloads. Establish service identity using VMware Aria Automation and vIDM integration. Enforce least-privilege service communication policies.
High	Vulnerability Management Gap Across Merged Assets	No centralized vulnerability scanning and remediation tracking for newly integrated 2,000 endpoints and their workloads. Unknown patch levels, missing security updates, and exploitable vulnerabilities create immediate attack vectors. No SLA-driven remediation process.	Deploy Qualys, Tenable, or Rapid7 integrated with NSX for continuous vulnerability scanning. Establish CVSS-based remediation SLAs (Critical: 7 days, High: 30 days). Automate patching workflows for non-critical systems. Correlate vulnerabilities with NSX segmentation policies to isolate high-risk workloads until remediated. Report metrics to CISO monthly.
High	NIST CSF Compliance Gaps - Detect Function	NIST CSF Detect function severely underdeveloped. Lack of continuous monitoring, anomaly detection, and incident detection capabilities mean organization cannot meet CSF-DE requirements. No evidence of detection controls for NIST Cybersecurity Framework audit.	Map current detection capabilities to NIST CSF framework (DE.AE, DE.CM, DE.DP). Implement NSX NDR, behavioral analytics in SIEM, and EDR for endpoints. Establish KRIs (Key Risk Indicators) aligned to NIST categories. Conduct quarterly NIST CSF assessments and close gaps with prioritized controls.
High	SOC 2 Type II Control Deficiencies	Flat network topology and lack of consistent monitoring/logging make SOC 2 Type II attestation high-risk. Missing evidence of network access controls, change management, and incident detection over 6-12 month review period. Lack of compensating controls documentation.	Implement NSX audit logging to SIEM with immutable storage (12+ month retention). Document all network policy changes with approval workflows. Establish change management process for NSX rules and VLAN assignments. Conduct SOC 2 readiness assessment and remediate gaps. Engage Big 4 auditor to validate controls 3-4 months before attestation.
Medium	Cloud Workload Protection Missing	AWS and Azure workloads lack consistent endpoint	Deploy vDefend ATP or equivalent for AWS/Azure workload protection.

SEVERITY	GAP / RISK AREA	DESCRIPTION	RECOMMENDED ACTION
		protection, runtime security, and workload segmentation. No CNAPP (Cloud-Native Application Protection Platform) in place. Kubernetes clusters (if present) lack pod security policies and network policies. Container image scanning absent.	Implement Kubernetes network policies for pod-to-pod segmentation. Enforce container image scanning in CI/CD pipeline (Aqua, Twistlock, or cloud-native solutions). Enable AWS VPC Flow Logs and Azure NSG Flow Logs with SIEM integration.
Medium	Data in Transit Encryption Incomplete	Site-to-site VPN provides encryption for inter-cloud traffic, but east-west traffic within VCF and cloud environments may not enforce consistent encryption. No TLS enforcement for service-to-service communication. Unencrypted management traffic (vSphere, NSX management) creates risk.	Enable vMotion encryption and VM-level encryption for all VMs. Enforce TLS 1.2+ for all management communications (vCenter, NSX Manager, SIEM). Implement NSX Data Security or equivalent for in-flight data classification and encryption. Audit all unencrypted north-south traffic and implement mandatory TLS.
Medium	Incident Response Playbook Gap for Network Security Events	No documented incident response procedures for network-based attacks such as lateral movement, DDoS, or data exfiltration. SIEM lacks pre-configured dashboards and automated response actions. Investigation team lacks network forensics tools and training.	Develop incident response playbooks for top 5 network attack scenarios (lateral movement, ransomware, data exfiltration, DDoS, compromised credentials). Implement automated response actions in SIEM (isolate VM, revoke credentials, block IP). Conduct quarterly tabletop exercises. Train SOC team on NSX flow analysis and network forensics tools.

Hardening recommendations			
12 actions · sorted by priority			
PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
Immediate	Implement NSX Distributed Firewall and Microsegmentation	Deploy NSX distributed firewall to enforce Zero Trust principles with application-level policies. Create security zones based on workload function, criticality, and data classification. Implement default-deny posture with explicit allow policies. Use NSX Intelligence to auto-generate segmentation policies based on observed traffic patterns.	VMware NSX, NSX Intelligence, vDefend ATP

PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
Immediate	Replace Legacy VPN with SASE	Decommission legacy VPN and deploy VMware SD-WAN with vDefend ATP integration. Implement MFA, certificate-based authentication, and device posture checking. Configure conditional access policies based on threat intelligence, device compliance, and user behavior. Enable split-tunneling restrictions for sensitive data access.	VMware SD-WAN, vDefend ATP, Okta/Entra ID
Immediate	Establish Merger Asset Security Baseline and Quarantine	Immediately segment all 2,000 merger endpoints into isolated VLAN with strict egress filtering. Conduct security inventory and vulnerability scan using NSX NDR and vulnerability scanners. Establish baseline hardening requirements (OS patches, AV, encryption, firewall rules). Implement compliance enforcement workflow before elevation to production network trust tier.	VMware NSX, vDefend ATP, Qualys/Tenable, SIEM
Immediate	Unify Multi-Cloud Security Policy and Visibility	Deploy centralized policy engine using SD-WAN for policy distribution across VCF, AWS, and Azure. Establish unified SIEM ingestion from all cloud environments and on-premises NSX. Implement infrastructure-as-code for network policies (Terraform modules for consistent deployment). Create unified threat dashboard showing cross-cloud security posture.	VMware SD-WAN, NSX, vDefend ATP, AWS CloudTrail, Azure Activity Logs, SIEM
Immediate	Deploy Network Detection and Response (NDR) for East-West Visibility	Implement NSX NDR or equivalent (Cisco Tetration, Darktrace) to detect behavioral anomalies and lateral movement patterns. Configure real-time alerting for suspicious east-west communications. Establish baseline network behavior models using machine learning. Integrate alerts with SIEM for correlation and incident investigation.	VMware NSX NDR, NSX Intelligence, SIEM
Short-term	Implement Application-Layer Threat Prevention at Perimeter	Deploy NSX Advanced Load Balancer (ALB) with integrated DPI-SSL/TLS inspection capability at north-south boundary. Integrate vDefend ATP threat prevention (IPS/ATP) for real-time malware and exploit detection.	NSX Advanced Load Balancer, vDefend ATP, Traditional Firewall (phased replacement)

PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
		Implement DLP policies for sensitive data exfiltration prevention. Enable rate limiting and bot detection for DDoS mitigation.	
Short-term	Establish Workload Identity and Zero Trust Service-to-Service Communication	Deploy NSX Service Mesh or Kubernetes-native service mesh (Istio/Linkerd) for mTLS-enforced service-to-service authentication. Implement workload identity using vIDM and Aria Automation integration. Define service-level access policies based on least privilege. Enable mutual TLS enforcement for all east-west communications.	VMware NSX Service Mesh, vIDM, VMware Aria Automation, Kubernetes
Short-term	Centralize and Automate Vulnerability Management	Deploy centralized vulnerability scanning platform (Qualys/Tenable/Rapid7) with NSX integration for automated discovery of all assets. Establish CVSS-based SLA-driven remediation process (Critical: 7 days, High: 30 days). Automate patching workflows for non-critical systems using NSX automation. Create executive dashboard showing vulnerability metrics and remediation status.	Qualys/Tenable/Rapid7, NSX, vDefend ATP, SIEM
Short-term	Achieve NIST CSF Compliance - Detect and Respond Functions	Map organizational controls to NIST CSF framework categories (Detect and Respond prioritized). Implement KRIs aligned to NIST metrics. Establish continuous monitoring through NSX, SIEM, and EDR integration. Document control evidence for audit readiness. Conduct quarterly NIST CSF self-assessments and close identified gaps.	NSX, vDefend ATP, SIEM, EDR, Audit tools
Short-term	Prepare for SOC 2 Type II Attestation	Implement 12+ month immutable logging for all network changes, access events, and security incidents using NSX audit logs and SIEM. Document change management process for network policies with approval workflows. Build control testing evidence repository. Engage Big 4 auditor 3-4 months before attestation period start. Remediate identified control gaps.	NSX, SIEM, Audit automation tools

PRIORITY	RECOMMENDATION	WHAT TO DO	TOOL ALIGNMENT
Medium-term	Extend Workload Protection to Cloud Environments	Deploy vDefend ATP or equivalent runtime protection for AWS and Azure VMs and containers. Implement container image scanning in CI/CD pipeline. Enable Kubernetes network policies and pod security policies for cluster segmentation. Implement cloud-native firewall rules (security groups, NSGs) aligned to NSX policies. Enable cloud flow log analysis in SIEM.	vDefend ATP, AWS Security Hub, Azure Defender, SIEM
Medium-term	Enforce Encryption for Data in Transit Across All Vectors	Enable VM-level encryption (vSAN encryption or Bitlocker) for all VMs in VCF. Enforce TLS 1.2+ for all management communications (vCenter, NSX Manager, vIDM). Implement NSX Data Security for classification and encryption of sensitive data in motion. Conduct TLS audit to identify and eliminate unencrypted protocols. Monitor encryption compliance through SIEM.	VMware NSX, vSAN, vIDM, Data Security tools

📅 90-day action plan				5 phases
#	PHASE	KEY ACTIONS	TIMELINE	
1	Phase 0: Emergency Stabilization	› Declare security incident response activation; escalate to CISO and board risk committee › Immediately isolate 2,000 merger endpoints into quarantine VLAN with restrictive ACLs; prevent unmonitored lateral movement › Conduct rapid risk assessment of merger assets using vulnerability scanners; identify and document critical exposures › Establish emergency network segmentation rules in traditional firewall to isolate high-risk merger subnets from production systems › Activate SIEM incident investigation team; search for signs of active compromise or lateral movement in historical logs › Document current state baseline: network topology, firewall rules, VPN user base, cloud connectivity; establish change control board › Brief executive leadership on critical findings and 90-day remediation timeline with resource requirements	🕒 Week 1-2	

#	PHASE	KEY ACTIONS	TIMELINE
2	Phase 1: Foundation - Access Control & Visibility (Week 3-8)	› Procure and stage SASE solution (SD-WAN + vDefend ATP) for remote access replacement; prepare for MFA/certificate-based auth migration › Deploy NSX distributed firewall in NSX Manager; configure in audit/monitor mode initially for policy validation › Implement NSX NDR or third-party NDR solution; baseline east-west traffic patterns and configure alerting for anomalies › Establish unified SIEM ingestion: configure NSX flow export, AWS CloudTrail, Azure Activity Logs, traditional firewall logs; validate data completeness › Conduct merger asset security inventory: enumerate all 2,000 endpoints, identify OS/software versions, check patch levels using automated scanners › Create security zones framework based on workload criticality and data classification; document mapping of systems to zones › Establish incident response playbook for lateral movement and network-based attacks; assign SOC team roles and responsibilities › Begin legacy VPN user migration planning; identify 25% of users for pilot SASE rollout; prepare MFA onboarding workflow	🕒 Week 3-8
3	Phase 2: Segmentation & Multi-Cloud Unification (Week 9-16)	› Deploy NSX distributed firewall policies for high-risk workloads (databases, file servers, identity systems); enforce default-deny › Implement NSX Service Mesh or Kubernetes service mesh for application tier with mTLS enforcement; pilot with 3-5 critical applications › Establish SD-WAN site-to-site connectivity between VCF data centers and AWS/Azure; activate centralized policy engine › Migrate 25% of remote workforce to SASE with MFA and device posture checking; monitor metrics and user experience; adjust controls › Complete vulnerability scan of all merger assets; establish remediation SLAs and create 90-day remediation plan › Implement baseline hardening for compliant merger systems: mandatory patches, antivirus, encryption; enforce through Aria Automation › Complete migration of 100% of merger endpoints from quarantine VLAN to segmented production zones with NSX microsegmentation	🕒 Week 9-16

#	PHASE	KEY ACTIONS	TIMELINE
		› Integrate vDefend ATP for cloud workload protection in AWS and Azure; configure runtime threat detection and response › Establish NIST CSF control evidence baseline; create roadmap for Detect and Respond function maturity improvement	
4	Phase 3: Perimeter Hardening & Advanced Detection (Week 17-20)	› Deploy NSX Advanced Load Balancer at north-south boundary with DPI-SSL/TLS inspection capability › Integrate vDefend ATP threat prevention (IPS/ATP) into perimeter; configure blocking for known malware and exploits › Implement DLP policies to prevent sensitive data exfiltration; log and alert on data classification matches › Migrate 100% of remote workforce to SASE with MFA; decommission legacy VPN infrastructure › Operationalize NSX NDR with playbook-driven incident response; validate detection accuracy and false positive rates › Establish centralized vulnerability management dashboard showing remediation SLA compliance across all environments › Complete SOC 2 Type II readiness assessment; identify control gaps and create remediation plan for 6-month attestation audit	🕒 Week 17-20
5	Phase 4: Compliance & Optimization (Week 21-24)	› Conduct full NIST CSF assessment against Detect and Respond functions; document control evidence › Finalize SOC 2 Type II control documentation; engage Big 4 auditor for pre-audit review 3 months prior to attestation › Implement encryption for all data in transit: enable VM encryption, enforce TLS 1.2+ for management, NSX Data Security for sensitive data › Deploy container image scanning in CI/CD pipeline; implement Kubernetes network policies for all containerized workloads › Establish KRIs aligned to NIST CSF framework; create executive reporting dashboard for quarterly board review › Conduct tabletop incident response exercise for lateral movement attack scenario; validate playbook and team readiness › Complete 100% expansion of NSX microsegmentation policies to all workloads; retire	🕒 Week 21-24

#	PHASE	KEY ACTIONS	TIMELINE
		traditional VLAN-based segmentation › Document lessons learned and create continuous improvement backlog for advanced security capabilities (CNAPP, advanced EDR, etc.)	